

Change record — P7 Security monitoring, SIEM and incident response

Change record written to the standard Halden uses for every change (feeds the change log and the P10 governance dashboard). In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended. The **Approved by** line is deliberately unsigned until a real review happens.

Field	Value
Change ID	CHG-2026-009
Title	P7 — Deploy central monitoring (Wazuh SIEM), availability monitoring and an incident response capability
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; see note on the lab</i>)
Date raised	2026-10-02
Planned implementation	Phases 0-6, out of hours where possible (SIEM01 and agents are internal, no user-facing downtime expected)
Category / risk	Security — Medium risk (monitoring is read-only; the one sensitive activity is the authorised simulation)
Affected services	Security monitoring and alerting (new), availability monitoring (new), incident response process (new)
Affected systems	SIEM01 (new), DC01, DC02, FS01, LNX01, OPS01, BKP01, WS01, WS02 (agents), FW01, FW02 (syslog)

1. Description of the change

Add centralised monitoring and a rehearsed incident response capability. A Wazuh SIEM on a new server (SIEM01) collects security events from every server and workstation and syslog from both firewalls, with Sysmon and tuned Windows advanced audit policy on the Windows hosts. Sixteen custom detection rules — mapped to ATT&CK — watch for identity abuse, credential theft, ransomware preparation and defence evasion, each with a runbook. Availability monitoring on OPS01 watches critical services and includes a backup heartbeat where a **missing** signal is the alert. An incident response plan, severity matrix, five playbooks and a management tabletop exercise complete the capability.

2. Reason for the change

Today an attack would likely not be noticed until it had succeeded: logs sit on each host and overwrite, nobody watches them, and there is no written incident process. Ransomware appears in 88% of small-business breaches and attackers spend time inside a network before encrypting — that window is only useful if it is monitored. The change closes the two job-ad gaps this project targets: monitoring system health, logs, alerts and security events, and identifying and responding to security incidents.

3. Impact and risk

Area	Impact	Mitigation
Users	No user-facing change, except a new staff status page	Brief staff; the monitoring policy explains what is tracked and why
Privacy	Monitoring sees staff system activity	Monitoring policy: purpose limitation, least collection, access logging, finite retention, and an explicit "not performance monitoring" commitment
Tier 0 systems	Agents and audit policy touch DC01/DC02	Low-risk, read-only telemetry; snapshot before each phase; rollback is a snapshot revert
Detection noise	A SIEM can flood the analyst	Use-case-driven collection, severity routing, narrow tuning with a written log
Authorised simulation	Attack simulation is inherently sensitive	Hard lab-only gates in <code>scripts/07</code> ; Tier 0 hosts refused; snapshots required; explicit owner approval before any run (AGENTS.md R6)
SIEM as a single point	One SIEM01 node is a single point of failure	Documented limitation; monitoring-gap note in the restore runbook; a second node is out of scope for this lab

4. Implementation plan (phases)

Phase	Work	Windows	Verification
0	Design document: log sources, detection approach, triage, IR model	2026-10-02	Design reviewed against the plan
1	SIEM01 up; agents on all sources; Sysmon; audit policy; firewall syslog	Out of hours	Agents all Active; Sysmon running; <code>auditpol</code> output
2	16 custom rules installed and tested with <code>wazuh-logtest</code>	Out of hours	Rules file + logtest output per rule
3	Authorised simulation; record which rules fired	Out of hours, snapshotted	Sanitized alert extract; coverage matrix filled from real output
4	Menu tuning with a written log	After 3-5 days of normal activity	Before/after alert counts; tuning-log entries
5	Availability monitoring; status page; backup heartbeat	Out of hours	Uptime Kuma dashboard; status page; push monitor
6	IR plan, 5 playbooks, one lab incident, tabletop	Scheduled	Incident timeline; tabletop report (outcomes filled after the run)

5. Test plan (acceptance)

1. Every host reports to Wazuh (agent list all Active).
2. `wazuh-logtest` matches a captured sample for each rule with the intended level and description.
3. The approved simulation fires each mapped rule, or records it as not fired **with a reason**

(Defender prevented it, or it needs tuning).

1. Stopping an agent raises D15 after the expected interval.
2. A backup that does not call the heartbeat turns the Uptime Kuma backup monitor down.
3. Firewall syslog from FW01 appears in Wazuh.
4. The tabletop produces a report with tracked actions with owners and dates.

6. Backout plan

Each phase is snapshotted before it runs (`snap-p7-ph<N>-before`). Backout for any phase is to revert the snapshot and re-run the previous phase's scripts, which are idempotent. On SIEM01, the stack and its data live in Docker volumes under `/opt/wazuh` , so a snapshot revert restores the previous state cleanly. **No simulation ever runs on DC01/DC02/FS01**, and the single optional DC-touching test is off by default, double-gated, and requires its own snapshot. Windows audit-policy and Sysmon changes are reversible with `auditpol` defaults and `sysmon64 -u` .

7. Post-implementation review

To be completed when the last phase is verified: actual completion date, acceptance test results, the alert-noise figures before and after tuning, and whether any phase overran. Results are recorded in `projects/p07-siem-incident-response/README.md` with a source file for every number.

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test results are real; the business approval line represents the lab owner's decision, not a real customer sign-off, and it is left unsigned until a real review.